

Narrativa Explicativa de la Encuesta TRIKE

Por qué preguntamos lo que preguntamos

1. El contexto: amenazas crecientes, paciencia menguante

En los últimos años, los incidentes de ciberseguridad en España no han dejado de marcar récords, con más de 97.000 incidentes gestionados por INCIBE solo en 2024 y un crecimiento cercano al 17 % respecto al año anterior. [web:22][web:26]

Mientras la superficie de ataque se expande, la paciencia de reguladores, clientes y ciudadanos tiende más bien al camino opuesto.

La Directiva NIS2 y su transposición en España, junto con otras normas como el RGPD o el ENS, no se han redactado para decorar el Boletín Oficial del Estado: exigen, con una seriedad algo seca, que las organizaciones gestionen el riesgo de forma estructurada, midan lo que hacen y puedan explicarlo a quien corresponda. [web:17][web:20][web:23]

2. TRIKE como prisma, no como dogma

TRIKE nació como metodología de modelado de amenazas, pero aquí lo usamos como prisma: Threat, Risk, Impact, Knowledge y Evaluation.

Cada bloque de la encuesta está diseñado para reflejar una de estas dimensiones sin presuponer que la organización “habla TRIKE” en su día a día.

- Threat: cómo se identifica, describe y mide aquello que puede ir mal.
- Risk: cómo se estructura, cuantifica y gobierna la incertidumbre.
- Impact: cómo se estima la magnitud del daño cuando las cosas efectivamente van mal.
- Knowledge: cómo se aprende, explícita e implícitamente, de amenazas e incidentes.
- Evaluation: cómo se evalúa todo lo anterior y se corrige el rumbo.

La encuesta no pregunta “¿utiliza TRIKE?”, sino “¿qué hace usted –llámelo como quiera– para lidiar con cada uno de estos bloques fundamentales?”.

3. Del incidente aislado al ecosistema

Muchos marcos siguen pensando el incidente como un fenómeno aislado: algo que le sucede a “mi” sistema en “mi” perímetro.

La realidad actual –con cadenas de suministro densas, servicios cloud ubicuos y requisitos de resiliencia a nivel de país– exige pensar en términos de ecosistema.

Esto se refleja en preguntas sobre:

- Impacto sistémico (efectos en cadena de suministro, terceros, ecosistemas).
- Benchmarking frente a datos sectoriales y nacionales.
- Alineamiento con marcos europeos como NIS2 y recomendaciones de ENISA. [web:23][web:18]

No se trata solo de proteger “mi” organización, sino de asumir que formamos parte de un tejido interdependiente en el que la caída de uno puede sacudir a muchos.

4. La dimensión incómoda: medir el impacto de verdad

Medir incidentes es relativamente sencillo: contar casos.

Medir impacto es otro asunto: cuantificar euros, horas de parada, usuarios afectados, sanciones potenciales, erosión de confianza.

La encuesta insiste en:

- Registros de impacto económico (P3.1).
- Duración de interrupciones de servicios esenciales (P3.2).
- Clasificaciones objetivas de impacto (P3.3).
- Consideración de sanciones regulatorias y efectos reputacionales (P3.4–P3.5).

No es casual: NIS2 y las propias aseguradoras solo se toman en serio lo que se puede traducir –directa o indirectamente– en coste, continuidad y responsabilidad. [web:19][web:20][web:22]

5. Knowledge: el cuello de botella silencioso

La dimensión Knowledge es el punto en el que el discurso heroico suele tropezar con la realidad: falta de talento, falta de tiempo, falta de procesos para aprender de los errores. [web:16][web:25]

Las preguntas sobre:

- Programas de inteligencia de amenazas.
- Lecciones aprendidas y post-mortem.
- Formación y cultura organizativa.

buscan medir hasta qué punto la organización es capaz de convertir incidentes y near-misses en conocimiento reutilizable, en lugar de coleccionar cicatrices sin memoria. [web:25]

6. Evaluation: la hora de la verdad

Cualquier modelo –TRIKE, STRIDE o la servilleta del bar– vale lo que valga su revisión periódica.

La dimensión Evaluation observa:

- Si se revisan controles y modelos de amenazas.
- Si las auditorías son meros trámites o palancas de mejora.
- Si los resultados influyen en prioridades y recursos.

El espíritu de NIS2 y de las guías de ENISA es claro: la gestión del riesgo de ciberseguridad no es un “proyecto”, sino un proceso permanente. [web:23][web:28]

La encuesta intenta capturar si la organización vive esa realidad... o sigue esperando que “cuando pase la tormenta” podrá volver a la normalidad de siempre.

7. IGM y ROI: números con sentido

Hablar de madurez sin números es cómodo, pero poco accionable.

Por eso, junto con la encuesta se propone un esquema de Índice Global de Madurez (IGM) y herramientas para aproximar el ROI de las inversiones en ciberseguridad.

- El IGM permite comparar en el tiempo y entre organizaciones sin pretender reducir la realidad a un solo número mágico.
- El ROI, aun aproximado, ayuda a dialogar con dirección y finanzas en un idioma que comprenden: cuánto costaría no hacer nada, y cuánto estamos evitando con lo que hacemos.

No hay promesa de precisión absoluta; solo la aspiración de que, por una vez, los números ayuden más de lo que confunden.

8. ¿Y ahora qué?

La encuesta no resuelve nada por sí sola.

Lo que sí hace es poner sobre la mesa preguntas incómodas, pero necesarias, acerca de:

- Cómo pensamos las amenazas.
- Cómo medimos el riesgo.
- Cómo asumimos y cuantificamos el impacto.
- Cómo aprendemos y enseñamos.
- Cómo evaluamos y corregimos.

A partir de ahí, cada organización decide si la TRIKE es un marco útil o un espejo demasiado sincero. Nosotros, al menos, prometemos no culpar al espejo.